

GitHub security features

An overview of GitHub's security features.

About GitHub's security features

GitHub's security features help keep your code and secrets secure in repositories and across organizations.

- * Some features are available for all repositories by default.
- * Additional features are available to enterprises that purchase a GitHub Advanced Security product:
 - * [GitHub Secret Protection](#available-with-github-secret-protection)
 - * [GitHub Code Security](#available-with-github-code-security)

Available for all GitHub plans

The following security features are available for you to use, regardless of the GitHub plan you are on. You don't need to purchase GitHub Secret Protection or GitHub Code Security to use these features.

Security policy

Make it easy for your users to confidentially report security vulnerabilities they've found in your repository. For more information, see [Adding a security policy to your repository](/en/enterprise-server@3.22/code-security/how-tos/report-and-fix-vulnerabilities/configure-vulnerability-reporting/add-security-policy).

Dependency graph

The dependency graph allows you to explore the ecosystems and packages that your repository depends on and the repositories and packages that depend on your repository.

You can find the dependency graph on the **Insights** tab for your repository. For more information, see [Dependency graph](/en/enterprise-server@3.22/code-security/concepts/supply-chain-security/dependency-graph).

Software Bill of Materials (SBOM)

You can export the dependency graph of your repository as an SPDX-compatible, Software Bill of Materials (SBOM). For more information, see [Exporting a software bill of materials for your repository](/en/enterprise-server@3.22/code-security/how-tos/secure-your-supply-chain/establish-provenance-and-integrity/export-dependencies-as-sbom).

GitHub Advisory Database

The GitHub Advisory Database contains a curated list of security vulnerabilities that you can view, search, and filter. For more information, see [Browsing security advisories in the GitHub Advisory Database](/en/enterprise-server@3.22/code-security/how-tos/report-and-fix-vulnerabilities/fix-reported-vulnerabilities/browse-advisory-database).

Dependabot alerts and security updates

View alerts about dependencies that are known to contain security vulnerabilities,

and choose whether to have pull requests generated automatically to update these dependencies. For more information, see [Dependabot alerts](/en/enterprise-server@3.22/code-security/concepts/supply-chain-security/dependabot-alerts) and [Dependabot security updates](/en/enterprise-server@3.22/code-security/concepts/supply-chain-security/dependabot-security-updates).

You can also use default Dependabot auto-triage rules curated by GitHub to automatically filter out a substantial amount of false positives.

For an overview of the different features offered by Dependabot and instructions on how to get started, see [Dependabot quickstart guide](/en/enterprise-server@3.22/code-security/tutorials/secure-your-dependencies/dependabot-quickstart).

Dependabot malware alerts

On GitHub.com and GitHub Enterprise Server 3.22+, you can view alerts for malicious dependencies in your repository. See [Dependabot malware alerts](/en/enterprise-server@3.22/code-security/concepts/supply-chain-security/malware-alerts).

Dependabot version updates

Use Dependabot to automatically raise pull requests to keep your dependencies up-to-date. This helps reduce your exposure to older versions of dependencies. Using newer versions makes it easier to apply patches if security vulnerabilities are discovered, and also makes it easier for Dependabot security updates to successfully raise pull requests to upgrade vulnerable dependencies. You can also customize Dependabot version updates to streamline their integration into your repositories. For more information, see [Dependabot version updates](/en/enterprise-server@3.22/code-security/concepts/supply-chain-security/dependabot-version-updates).

Repository rulesets

Enforce consistent code standards, security, and compliance across branches and tags. For more information, see [About rulesets](/en/enterprise-server@3.22/repositories/configuring-branches-and-merges-in-your-repository/managing-rulesets/about-rulesets).

Available with GitHub Secret Protection

For accounts on GitHub Enterprise Server, you can access additional security features when you purchase **GitHub Secret Protection**.

GitHub Secret Protection includes features that help you detect and prevent credential leaks and secret sprawl, such as secret scanning for detecting hardcoded credentials and push protection for blocking them before they reach your repository.

These features are available for all repository types.

<!--Hiding information on setting up a trial for now, as there is no available link for fpt yet. Needs versioning for fpt, ghes and ghes.
For information about how you can try GitHub Secret Protection for free, see [AUTOTITLE](/code-security/tutorials/trialing-github-advanced-security/trial-advanced-security).
-->

Secret scanning

Automatically detect hardcoded credentials that have been checked into a repository. You can view alerts for any secrets that GitHub finds in your code, in the  tab of your repository, so you can respond to credential leaks quickly. For more information, see [Secret scanning](/en/enterprise-server@3.22/code-security/concepts/secret-security/secret-scanning).

Push protection

Push protection proactively scans your code, and any repository contributors' code, for hardcoded secrets during the push process and blocks the push if any credential leaks are detected. If a contributor bypasses the block, an alert is generated. For more information, see [Push protection](/en/enterprise-server@3.22/code-security/concepts/secret-security/push-protection).

Delegated bypass for push protection

Delegated bypass for push protection lets you control which individuals, roles, and teams:

- * Can bypass push protection
- * Are exempt from push protection
- * Can review bypass requests from other contributors

For more information, see [Delegated bypass for push protection](/en/enterprise-server@3.22/code-security/concepts/secret-security/delegated-bypass).

Custom patterns

You can define custom patterns to identify secrets that are not detected by the default patterns supported by secret scanning, such as patterns that are internal to your organization. For more information, see [Defining custom patterns for secret scanning](/en/enterprise-server@3.22/code-security/how-to-secure-your-secrets/customize-leak-detection/define-custom-patterns).

<!--Hiding security overview for earlier GHES versions, so it isn't duplicated below-->

Security overview

Security overview allows you to review the overall security landscape of your organization, view trends and other insights, and manage security configurations, making it easy to monitor your organization's security status and identify the repositories and organizations at greatest risk. For more information, see [Security overview](/en/enterprise-server@3.22/code-security/concepts/security-at-scale/security-overview).

Available with GitHub Code Security

For accounts on GitHub Enterprise Server, you can access additional security features when you purchase **GitHub Code Security**.

GitHub Code Security includes features that help you find and fix vulnerabilities, like code scanning, premium Dependabot features, and dependency review.

These features are available for all repository types.

<!--Hiding information on setting up a trial for now, as there is no available link for fpt yet. Needs versioning for fpt, ghes & ghes.

For information about how you can try GitHub Code Security for free, see [AUTOTITLE](/code-security/tutorials/trialing-github-advanced-security/trial-advanced-security).

-->

Code scanning

Automatically detect security vulnerabilities and coding errors in new or modified code. Potential problems are highlighted, with detailed information, allowing you to fix the code before it's merged into your default branch. For more information, see [Code scanning](/en/enterprise-server@3.22/code-security/concepts/code-scanning/code-scanning).

CodeQL CLI

Run CodeQL processes locally on software projects or to generate code scanning results for upload to GitHub. For more information, see [CodeQL CLI](/en/enterprise-server@3.22/code-security/concepts/code-scanning/codeql/codeql-cli).

Custom auto-triage rules for Dependabot

Help you manage your Dependabot alerts at scale. With custom auto-triage rules you have control over the alerts you want to ignore, snooze, or trigger a Dependabot security update for. For more information, see [Dependabot alerts](/en/enterprise-server@3.22/code-security/concepts/supply-chain-security/dependabot-alerts) and [Customizing auto-triage rules to prioritize Dependabot alerts](/en/enterprise-server@3.22/code-security/how-to-secure-your-supply-chain/manage-your-dependency-security/auto-triage-dependabot-alerts).

Dependency review

Show the full impact of changes to dependencies and see details of any vulnerable versions before you merge a pull request. For more information, see [Dependency review](/en/enterprise-server@3.22/code-security/concepts/supply-chain-security/dependency-review).

Security overview

Security overview allows you to review the overall security landscape of your organization, view trends and other insights, and manage security configurations, making it easy to monitor your organization's security status and identify the repositories and organizations at greatest risk. For more information, see [Security overview](/en/enterprise-server@3.22/code-security/concepts/security-at-

scale/security-overview).

Further reading

- * [GitHub's plans](/en/enterprise-server@3.22/get-started/learning-about-github/githubs-plans)
- * [About GitHub Advanced Security](/en/enterprise-server@3.22/get-started/learning-about-github/about-github-advanced-security)
- * [GitHub language support](/en/enterprise-server@3.22/get-started/learning-about-github/github-language-support)